

CESI École d'Ingénieurs



Campus de La Rochelle

Application de la Démarche Scientifique (ADS)

Semestre 2 — 2025/2026

Sécuriser l'accès distant en télétravail :

Du VPN classique au Zero Trust Network Access (ZTNA)

Étude comparative et évaluation expérimentale

Rédigé par :

Sylvère ELAT

Filière : Systèmes, Réseaux & Cybersécurité (SRC)

Juin 2026

Remerciements

Je tiens à exprimer ma reconnaissance à l'équipe pédagogique du CESI École d'Ingénieurs, campus de La Rochelle, pour la qualité de l'encadrement et la pertinence des enseignements dispensés tout au long de cette formation en Systèmes, Réseaux et Cybersécurité.

Je remercie particulièrement M. PELISSIER Mathis pour son accompagnement méthodologique, ses retours constructifs et sa disponibilité durant les différentes étapes de ce projet d'Application de la Démarche Scientifique.

Mes remerciements vont également à mes camarades de promotion, dont les échanges et les retours ont enrichi ma réflexion sur les architectures de sécurité réseau.

Enfin, je remercie ma famille et mes proches pour leur soutien constant durant cette période exigeante.

Résumé

Depuis 2020, la généralisation du télétravail a profondément redéfini le périmètre des systèmes d'information des entreprises. Les solutions historiques d'accès distant, fondées sur le modèle périmétrique (VPN classique), montrent aujourd'hui leurs limites face aux attaques modernes : phishing massif, vol d'identifiants, déplacement latéral après compromission, exposition de surfaces d'attaque sur Internet.

Ce rapport présente une étude comparative entre deux approches d'accès distant : le modèle VPN traditionnel et le modèle Zero Trust Network Access (ZTNA). La démarche scientifique adoptée s'articule autour de cinq étapes : cadrage, analyse de l'existant, état de l'art, proposition et validation expérimentale, conclusion.

Un banc d'essai a été conçu et déployé sur une infrastructure de virtualisation pour comparer concrètement les deux architectures selon deux dimensions : la sécurité (surface d'attaque, capacité de déplacement latéral, robustesse de l'authentification) et la performance réseau (latence, débit, gigue, perte de paquets).

Les résultats expérimentaux obtenus sur l'architecture VPN à base d'OpenVPN révèlent un coût significatif en performance : la latence est multipliée par 2,3 (de 1,53 ms à 3,55 ms), le débit TCP s'effondre de 805 Mbits/s à 8,81 Mbits/s (soit une division par 91), et la gigue UDP augmente d'un facteur 6,6. Sur le plan de la sécurité, le scan du réseau interne depuis la machine cliente connectée au VPN confirme la possibilité d'un déplacement latéral, démontrant la limite structurelle du modèle périmétrique. L'analyse comparative complète, intégrant l'architecture ZTNA déployée avec Pomerium, fait l'objet de la dernière phase du projet.

Mots-clés : Zero Trust, ZTNA, VPN, OpenVPN, Pomerium, télétravail, cybersécurité, accès distant, micro-segmentation, déplacement latéral, démarche scientifique.

Abstract

Since 2020, the widespread adoption of remote work has fundamentally reshaped the perimeter of corporate information systems. Traditional remote access solutions, based on the perimeter security model (classic VPN), now reveal significant limitations against modern attacks: large-scale phishing, credential theft, lateral movement after compromise, and exposure of attack surfaces on the public Internet.

This report presents a comparative study between two remote access approaches: the traditional VPN model and the Zero Trust Network Access (ZTNA) model. The scientific methodology follows five steps: scoping, analysis of existing solutions, state of the art, proposal and experimental validation, conclusion.

A test environment was designed and deployed on a virtualization infrastructure to concretely compare both architectures across two dimensions: security (attack surface, lateral movement capability, authentication robustness) and network performance (latency, throughput, jitter, packet loss).

Experimental results obtained on the OpenVPN architecture reveal a significant performance cost: latency increased by 132% (from 1.53 ms to 3.55 ms), TCP throughput collapsed from 805 Mbits/s to 8.81 Mbits/s (a 91-fold decrease), and UDP jitter increased by a factor of 6.6. From a security standpoint, scanning the internal network from the VPN-connected client successfully demonstrated lateral movement, confirming the structural limitation of the perimeter model. The complete comparative analysis, including the ZTNA architecture deployed with Pomerium, constitutes the final phase of the project.

Keywords: Zero Trust, ZTNA, VPN, OpenVPN, Pomerium, remote work, cybersecurity, remote access, micro-segmentation, lateral movement, scientific methodology.

Sommaire

Remerciements.....	2
Résumé	3
Abstract.....	4
Sommaire	5
Liste des figures.....	7
Liste des tableaux	8
Introduction générale	9
Problématique	10
Démarche scientifique adoptée	10
Annonce du plan	11
Chapitre 1 — Cadrage du sujet.....	12
1.1 Le télétravail et ses enjeux	12
1.2 Les menaces spécifiques au télétravail	13
1.2.1 Phishing et vol d'identifiants	13
1.2.2 Compromission de poste personnel	13
1.2.3 Déplacement latéral après intrusion	14
1.2.4 Exfiltration de données.....	14
1.3 Définition de la problématique	14
1.4 Objectifs du projet.....	15
1.5 Périmètre et limites de l'étude.....	15
Chapitre 2 — Analyse de l'existant : le VPN classique	16
2.1 Le modèle périmétrique classique	16
2.2 Le VPN : principes et fonctionnement.....	17
2.3 Limites structurelles du modèle VPN	18
2.3.1 La confiance implicite après authentification	18
2.3.2 L'absence de micro-segmentation.....	19
2.3.3 La surface d'attaque exposée	19
2.3.4 L'absence de vérification du poste client	19
2.3.5 L'impact sur les performances réseau	19
Chapitre 3 — État de l'art : le Zero Trust	20
3.1 Origine et philosophie du Zero Trust.....	20
3.2 Les trois principes fondamentaux	20
3.3 Les cinq piliers du Zero Trust.....	21
3.4 Le ZTNA : implémentation concrète.....	21
3.5 Limites et critiques du modèle Zero Trust	23
Chapitre 4 — Méthodologie expérimentale	24
4.1 Hypothèses de travail	24

4.2 Indicateurs et métriques retenus.....	24
4.2.1 Métriques de performance réseau.....	24
4.2.2 Métriques de sécurité	25
4.3 Protocole expérimental	25
4.4 Outils de mesure	25
Chapitre 5 — Réalisation du POC.....	26
5.1 Architecture du banc d'essai.....	26
5.2 Choix techniques et justifications	27
5.3 Déploiement de l'architecture VPN (OpenVPN)	28
5.4 Déploiement de nginx sur vm-serveur	30
Chapitre 6 — Résultats expérimentaux et analyse	31
6.1 Résultats de performance.....	31
6.1.1 Mesure de la latence	31
6.1.2 Mesure du débit TCP	32
6.1.3 Mesure de la gigue et de la perte UDP.....	34
6.1.4 Temps de réponse applicatif HTTP	35
6.2 Résultats de sécurité	35
6.2.1 Surface d'attaque exposée.....	35
6.2.2 Démonstration du déplacement latéral	37
6.3 Synthèse comparative des résultats VPN	38
6.4 Discussion et confrontation aux hypothèses	38
Conclusion générale	40
Bibliographie	42
Normes et publications de référence	42
Documentation technique	42
Rapports et études du marché	42
Ressources complémentaires	42

Liste des figures

⚠ À régénérer automatiquement dans Word après ajout des captures (onglet Références → Insérer une table des illustrations).

Figure 1 — Schéma général du modèle périmétrique

Figure 2 — Fonctionnement d'un tunnel VPN classique

Figure 3 — Les 5 piliers du Zero Trust (modèle CISA)

Figure 4 — Architecture broker ZTNA

Figure 5 — Schéma général du banc d'essai

Figure 6 — Configuration réseau VirtualBox des trois VMs

Figure 7 — Status systemd du service OpenVPN sur vm-securite

Figure 8 — Établissement du tunnel côté client (Initialization Sequence Completed)

Figure 9 — Table de routage du client VPN après connexion

Figure 10 — Capture du test de latence (ping vm-client → vm-serveur via tunnel)

Figure 11 — Capture iperf3 : test de débit TCP via VPN

Figure 12 — Capture iperf3 : test de gigue UDP via VPN

Figure 13 — Capture nmap : surface d'attaque du serveur OpenVPN

Figure 14 — Capture nmap : démonstration du déplacement latéral depuis vm-client

Liste des tableaux

Tableau 1 — Comparaison VPN classique vs ZTNA

Tableau 2 — Métriques de performance retenues

Tableau 3 — Métriques de sécurité retenues

Tableau 4 — Configuration matérielle des machines virtuelles

Tableau 5 — Adressage IP du banc d'essai

Tableau 6 — Mesures de latence (baseline vs VPN)

Tableau 7 — Mesures de débit TCP (baseline vs VPN)

Tableau 8 — Mesures de gigue et perte UDP (baseline vs VPN)

Tableau 9 — Synthèse comparative complète des résultats VPN

Tableau 10 — Surface d'attaque et déplacement latéral mesurés

Introduction générale

L'année 2020 a constitué un tournant majeur dans l'organisation du travail à l'échelle mondiale. La pandémie de COVID-19 a contraint les entreprises à basculer en quelques semaines vers le télétravail généralisé, exposant des dizaines de millions de collaborateurs à un nouveau mode d'accès aux ressources de leur employeur. Cette transformation, initialement perçue comme temporaire, est devenue structurelle : selon les études récentes du marché, le travail hybride concerne désormais une majorité des emplois du secteur tertiaire.

Cette mutation a profondément déstabilisé un paradigme de sécurité réseau vieux de plusieurs décennies : le modèle périmétrique. Selon cette approche, la sécurité d'un système d'information repose sur une frontière nette souvent matérialisée par un pare-feu, séparant un « intérieur » (le réseau d'entreprise, considéré comme de confiance) d'un « extérieur » (Internet, considéré comme hostile). Dans un tel modèle, le rôle des solutions d'accès distant au premier rang desquelles les Réseaux Privés Virtuels (VPN) est de « faire entrer » l'utilisateur distant à l'intérieur du périmètre via un tunnel chiffré.

Or, ce paradigme repose sur une hypothèse qui n'est plus vraie aujourd'hui : *l'intérieur du réseau est sûr, l'extérieur est dangereux*. Plusieurs phénomènes convergents ont rendu cette hypothèse caduque. D'une part, la généralisation du télétravail et du Bring Your Own Device (BYOD) a multiplié les points d'accès au système d'information depuis des environnements non maîtrisés (réseaux domestiques, Wi-Fi publics, postes personnels). D'autre part, l'évolution des menaces en particulier le phishing ciblé, le vol d'identifiants, et les ransomwares à propagation latérale a démontré qu'une fois un attaquant parvenu à pénétrer le périmètre, il pouvait se propager facilement à l'ensemble du système d'information.

Face à ce constat, une nouvelle approche s'est imposée dans la littérature spécialisée et chez les éditeurs de solutions de cybersécurité : le **Zero Trust**. Initialement théorisé par John Kindervag (Forrester) en 2010, ce modèle repose sur une devise désormais célèbre : « **Never trust, always verify** » (« Ne jamais faire confiance, toujours vérifier »). Contrairement au modèle périmétrique, le Zero Trust postule qu'aucun utilisateur, aucun appareil, aucune connexion ne doit bénéficier d'une confiance par défaut y compris lorsqu'il se trouve à l'intérieur du réseau. Chaque accès à chaque ressource doit être authentifié et autorisé en continu, sur la base de signaux contextuels multiples.

L'implémentation concrète des principes Zero Trust pour l'accès distant porte un nom spécifique : le **Zero Trust Network Access (ZTNA)**. Cette approche, qui se positionne comme un successeur direct du VPN traditionnel, repose sur un broker centralisé qui

authentifie et autorise chaque requête utilisateur vers chaque application, sans jamais exposer le réseau interne dans son ensemble. Les analystes du secteur (Gartner, Forrester) considèrent aujourd'hui le ZTNA comme l'évolution naturelle des architectures d'accès distant pour les années à venir.

Problématique

Si la rupture conceptuelle entre VPN et ZTNA est largement documentée dans la littérature, la question de l'évaluation expérimentale concrète reste, elle, sous-traitée. Les bénéfices de sécurité du ZTNA sont souvent affirmés sans démonstration mesurable, et la question des performances réseau pourtant déterminante pour l'expérience utilisateur en télétravail est rarement quantifiée dans des conditions reproductibles. Cette double exigence sécurité accrue et performances préservées constitue le fil rouge de notre étude. Elle peut se formuler ainsi :

Comment garantir un accès distant sécurisé aux ressources sensibles pour les collaborateurs en télétravail, sans dégrader les performances réseau ?

Cette problématique recouvre deux dimensions complémentaires que nous explorons conjointement : une dimension sécurité (dans quelle mesure le modèle ZTNA réduit-il effectivement la surface d'attaque et limite-t-il le déplacement latéral par rapport au modèle VPN classique ?) et une dimension performance (cette amélioration de la sécurité s'opère-t-elle au prix d'une dégradation significative des performances réseau ?).

Démarche scientifique adoptée

Pour répondre à cette problématique de manière rigoureuse, nous avons structuré notre travail selon la démarche scientifique en cinq étapes enseignée dans le cadre de l'Application de la Démarche Scientifique (ADS) : cadrage du sujet (Chapitre 1), analyse de l'existant via le VPN classique (Chapitre 2), état de l'art sur le Zero Trust (Chapitre 3), proposition et validation expérimentale (Chapitres 4 et 5), conclusion et perspectives (Chapitre 6 et Conclusion générale).

Annonce du plan

Le présent rapport est structuré en six chapitres reflétant cette démarche. Le Chapitre 1 cadre le sujet en présentant les enjeux du télétravail et les menaces spécifiques auxquelles il expose les entreprises. Le Chapitre 2 analyse l'existant en détaillant le fonctionnement du VPN classique et en identifiant ses limites structurelles. Le Chapitre 3 constitue l'état de l'art : il présente les fondements théoriques et pratiques du modèle Zero Trust et de son implémentation ZTNA. Le Chapitre 4 formalise la méthodologie expérimentale retenue : hypothèses, indicateurs, protocole et outils de mesure. Le Chapitre 5 décrit la réalisation concrète du banc d'essai, depuis la mise en place de l'environnement de virtualisation jusqu'au déploiement des deux architectures comparées. Enfin, le Chapitre 6 présente et analyse les résultats expérimentaux, avant de tirer les enseignements globaux de l'étude dans la conclusion générale.

Chapitre 1 — Cadrage du sujet

Ce premier chapitre pose le décor de l'étude. Il s'agit de définir précisément le contexte dans lequel s'inscrit notre problématique, d'identifier les menaces qui pèsent sur l'accès distant en télétravail, et de délimiter le périmètre du projet.

1.1 Le télétravail et ses enjeux

Le télétravail, défini comme l'exercice d'une activité professionnelle hors des locaux de l'employeur grâce aux technologies de l'information et de la communication, n'est pas un phénomène récent en soi. Il existait avant 2020, mais restait minoritaire et confiné à certains profils (commerciaux nomades, métiers du conseil, équipes de développement réparties). La crise sanitaire de 2020 a brutalement changé d'échelle : en quelques semaines, des entreprises entières ont dû basculer en télétravail intégral, souvent sans préparation technique adéquate.

Cette bascule a révélé une réalité que le monde de la cybersécurité connaissait, mais que les directions générales découvraient : **le télétravail change radicalement la surface d'attaque d'une entreprise**. Là où l'environnement de bureau était maîtrisé (réseau interne sécurisé, postes gérés par la DSI, locaux physiquement protégés), l'environnement de télétravail introduit une multitude de variables non contrôlées.

Du point de vue d'un attaquant, le télétravail offre plusieurs opportunités nouvelles. Le collaborateur en télétravail utilise sa box Internet personnelle (souvent mal configurée). Il se connecte parfois depuis des réseaux Wi-Fi publics (cafés, hôtels, aéroports). Son ordinateur peut être partagé avec sa famille, ce qui multiplie les risques de contamination par des logiciels malveillants. Aucune surveillance physique ne garantit que la personne devant l'écran est bien celle qu'on croit. Les mises à jour de sécurité ne sont plus appliquées automatiquement par la DSI.

Du point de vue de l'entreprise, le défi devient donc le suivant : comment continuer à protéger les ressources sensibles (données clients, données financières, propriété intellectuelle, secrets industriels) lorsqu'on ne contrôle plus l'environnement dans lequel ces ressources sont consultées ? Cette question dépasse largement la dimension technique : elle implique une réflexion sur les modèles de confiance, sur la gouvernance des accès, et sur l'expérience utilisateur — un télétravailleur dont les outils sont trop contraignants finira par les contourner.

1.2 Les menaces spécifiques au télétravail

Pour bien comprendre l'enjeu de la sécurisation de l'accès distant, il est essentiel d'identifier précisément les menaces auxquelles s'expose une entreprise dont les collaborateurs travaillent à distance. Nous avons retenu quatre menaces majeures, qui constituent autant de scénarios d'attaque réels et documentés.

1.2.1 Phishing et vol d'identifiants

Le **phishing (hameçonnage)** demeure aujourd'hui la porte d'entrée numéro un des cyberattaques contre les entreprises. Selon les rapports successifs de l'ANSSI et du Verizon Data Breach Investigations Report, plus de 80 % des incidents de sécurité commencent par une intrusion via le facteur humain, dont une majorité par phishing.

Le principe est simple : un attaquant envoie à un collaborateur un message électronique imitant un correspondant de confiance (DSI interne, fournisseur cloud, banque, administration). Ce message contient un lien vers une fausse page de connexion, sur laquelle la victime saisit ses identifiants — qui sont immédiatement récupérés par l'attaquant. En télétravail, le risque est amplifié pour plusieurs raisons : isolation du collaborateur qui ne peut pas demander confirmation à un collègue, multiplication des outils numériques sollicitant des authentications, baisse de vigilance liée à la fatigue informationnelle.

Une fois en possession d'identifiants valides, l'attaquant peut se connecter au VPN d'entreprise *exactement comme le ferait le collaborateur légitime*. C'est précisément ce point qui révèle la limite structurelle du modèle périmétrique : une fois l'authentification réussie, le système n'a aucun moyen de distinguer un utilisateur légitime d'un attaquant disposant des mêmes identifiants.

1.2.2 Compromission de poste personnel

Le télétravail s'accompagne souvent — par contrainte ou par choix — de l'utilisation par le collaborateur de son ordinateur personnel pour accéder aux ressources de l'entreprise (modèle dit BYOD, pour Bring Your Own Device). Or, ce poste personnel échappe par définition au contrôle de la DSI : pas de gestion centralisée des mises à jour, pas d'antivirus d'entreprise, pas de durcissement de la configuration.

Un poste personnel peut être infecté par un logiciel malveillant (cheval de Troie, keylogger, ransomware) sans que ni le collaborateur ni la DSI n'en aient connaissance. Lorsque ce poste se connecte au VPN d'entreprise, l'infection entre avec lui dans le réseau interne. Le tunnel chiffré, censé protéger contre les attaques externes, devient alors un canal d'infiltration pour la menace qui se trouvait déjà dans le poste compromis.

1.2.3 Déplacement latéral après intrusion

Une fois un attaquant parvenu à pénétrer le réseau de l'entreprise (par phishing, par compromission de poste ou par exploitation d'une vulnérabilité), il ne reste presque jamais sur la machine d'entrée. Son objectif réel est d'atteindre des ressources de plus grande valeur : serveurs de fichiers, bases de données clients, contrôleurs de domaine Active Directory, données financières. Cette progression de machine en machine, de service en service, à l'intérieur du réseau interne, porte un nom : **le déplacement latéral** (en anglais, *lateral movement*).

Le déplacement latéral est aujourd'hui considéré par la quasi-totalité des analystes en cybersécurité comme la menace centrale à neutraliser. Pour les attaques par ransomware en particulier, c'est la capacité de l'attaquant à se propager rapidement sur l'ensemble du réseau qui détermine l'ampleur du dommage final. Un ransomware confiné à une seule machine est gérable ; un ransomware qui chiffre l'intégralité du Système d'Information paralyse l'entreprise.

Or, dans un modèle VPN classique, le déplacement latéral est par conception facilité : une fois authentifié, l'utilisateur (ou l'attaquant qui a usurpé son identité) accède à l'ensemble du sous-réseau d'entreprise. Aucun mécanisme natif ne limite ce qu'il peut atteindre. C'est précisément ce point que le ZTNA, par sa logique de micro-segmentation et d'accès par application, vise à corriger. Notre étude expérimentale (Chapitre 6) confirmera cette analyse par des mesures concrètes.

1.2.4 Exfiltration de données

L'exfiltration de données constitue l'objectif final de la plupart des attaques sophistiquées contre les entreprises. Une fois les données sensibles atteintes par déplacement latéral, l'attaquant cherche à les extraire vers l'extérieur — pour les revendre sur des marchés illégaux, les utiliser comme moyen de chantage (double extorsion combinée au ransomware), ou les divulguer publiquement pour nuire à la réputation de la cible.

Le télétravail facilite indirectement l'exfiltration : la frontière entre le poste de travail et l'extérieur étant moins nette, les flux sortants sont plus difficiles à analyser. Un attaquant qui contrôle un poste de télétravailleur peut faire transiter les données exfiltrées à travers des canaux apparemment légitimes (sessions VPN, services cloud, transferts chiffrés).

1.3 Définition de la problématique

À la lumière de l'analyse précédente, nous pouvons reformuler notre problématique avec davantage de précision. Le défi auquel l'entreprise moderne est confrontée n'est pas tant d'empêcher toute intrusion — l'expérience démontre que c'est statistiquement impossible à

grande échelle — que de concevoir un système d'accès distant tel que : une intrusion isolée ne se transforme pas en compromission généralisée ; la surface d'attaque exposée est minimale ; l'authentification est contextuelle et continue ; l'expérience utilisateur reste fluide. C'est exactement cet ensemble d'exigences que le modèle ZTNA prétend satisfaire, et dont notre étude expérimentale entend mesurer la réalité concrète.

1.4 Objectifs du projet

Le présent projet ADS poursuit quatre objectifs principaux, complémentaires les uns des autres : maîtriser les concepts fondamentaux des deux modèles d'accès distant ; identifier les différences structurelles entre les deux approches ; concevoir, déployer et instrumenter un banc d'essai reproductible ; produire une analyse comparative chiffrée et raisonnée.

1.5 Périmètre et limites de l'étude

Pour rester réaliste dans le cadre temporel et matériel d'un projet ADS de semestre, nous avons retenu OpenVPN (standard open source largement déployé) et Pomerium (solution ZTNA open source) comme représentants des deux modèles. Le banc d'essai est constitué de trois machines virtuelles. Le présent projet ne traite pas exhaustivement de la question de l'intégration à un fournisseur d'identité d'entreprise (Azure AD, Okta) ni du Device Trust avancé. Ces sujets sont abordés conceptuellement mais ne font pas l'objet de déploiements expérimentaux.

Ce premier chapitre nous a permis de poser le cadre de l'étude. Le chapitre suivant s'attache à analyser en profondeur la solution historique la plus déployée pour répondre à ces besoins d'accès distant : le VPN.

Chapitre 2 — Analyse de l'existant : le VPN classique

Ce deuxième chapitre se concentre sur l'analyse approfondie de la solution historiquement la plus déployée pour l'accès distant en entreprise : le Réseau Privé Virtuel, ou VPN (Virtual Private Network). Comprendre précisément le fonctionnement du VPN, ses présupposés architecturaux et ses limites structurelles constitue un prérequis indispensable à l'évaluation comparative que nous mènerons par la suite. Cette analyse est conduite selon l'étape « Analyse de l'existant » de la démarche scientifique.

2.1 Le modèle périmétrique classique

Avant même d'aborder la technologie VPN, il convient de comprendre le **paradigme de sécurité** dans lequel elle s'inscrit : le modèle périmétrique. Ce modèle, hérité de l'informatique d'entreprise des années 1980-1990, repose sur une métaphore architecturale simple : celle du château fort. Tout ce qui se trouve à l'intérieur des murs est de confiance ; tout ce qui se trouve à l'extérieur est suspect. Le rôle de la sécurité réseau consiste alors à contrôler les points de passage entre l'intérieur et l'extérieur — ces points de passage étant matérialisés par des dispositifs comme les pare-feu, les proxys et les passerelles.

Ce modèle a donné naissance à une architecture réseau désormais classique. Le réseau interne, séparé d'Internet par un pare-feu de périmètre, héberge l'ensemble des ressources de l'entreprise : serveurs de fichiers, applications métier, bases de données, contrôleurs Active Directory. Les utilisateurs au bureau bénéficient d'un accès direct à ces ressources, leur connexion étant considérée comme intrinsèquement digne de confiance — du seul fait qu'elle provient de l'intérieur des murs.

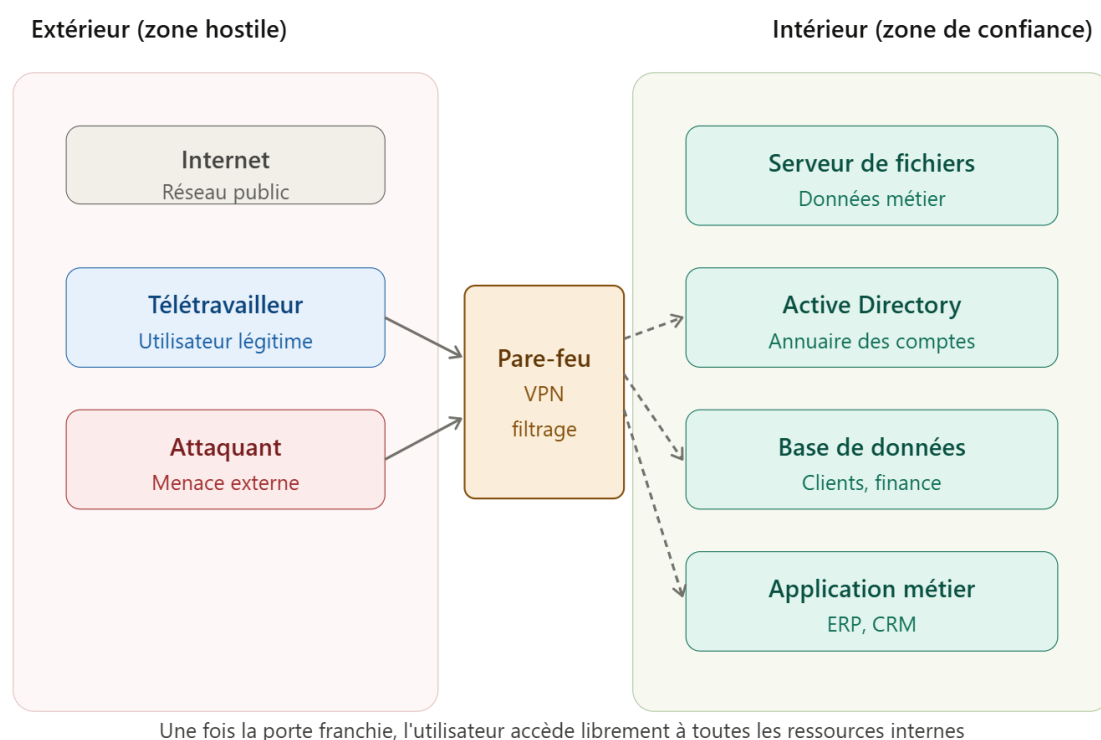


Figure 1 — Schéma général du modèle périmétrique

Le problème survient lorsque l'on doit donner accès à ce réseau interne à des utilisateurs *qui se trouvent géographiquement à l'extérieur* (commerciaux nomades, sites distants, et plus récemment télétravailleurs). La solution développée dès les années 1990 et toujours dominante aujourd'hui consiste à créer un « tunnel chiffré » qui prolonge virtuellement le réseau interne jusqu'au poste de l'utilisateur distant. Ce tunnel, c'est précisément ce qu'on appelle un VPN.

2.2 Le VPN : principes et fonctionnement

Un VPN est un dispositif logiciel ou matériel qui crée un canal de communication chiffré entre deux entités à travers un réseau public considéré comme non sûr — typiquement Internet. Ce canal, appelé tunnel, présente trois propriétés fondamentales : la confidentialité (les données qui y transitent sont chiffrées et donc illisibles pour un observateur extérieur), l'intégrité (les données ne peuvent pas être modifiées sans détection), et l'authentification (chaque extrémité du tunnel est assurée de l'identité de l'autre).

Concrètement, lorsqu'un collaborateur en télétravail souhaite accéder à une application interne de son entreprise, il lance un client VPN sur son poste. Ce client établit une connexion avec un serveur VPN exposé sur Internet par l'entreprise. Après une phase d'authentification,

le tunnel est établi. À partir de ce moment, tout le trafic réseau du collaborateur destiné à l'entreprise est encapsulé dans le tunnel et chiffré.

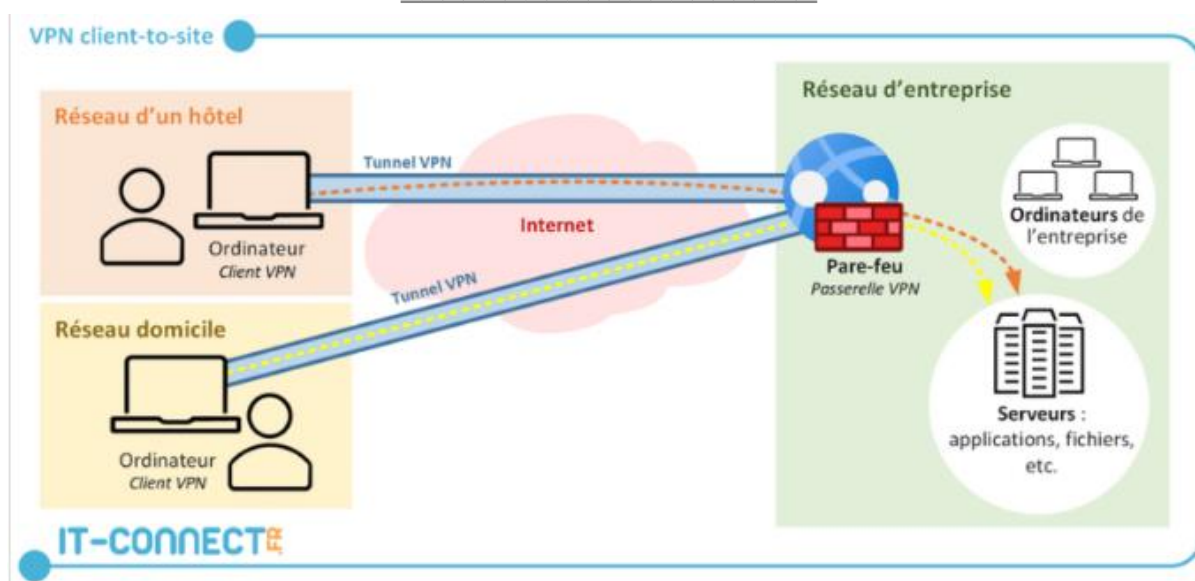


Figure 2 — Fonctionnement d'un tunnel VPN classique

Pour notre étude expérimentale, nous avons retenu **OpenVPN** comme représentant du modèle VPN classique. OpenVPN est un logiciel libre publié en 2001 qui s'est progressivement imposé comme le standard open source incontournable. Il repose sur la suite cryptographique TLS et utilise des certificats X.509 pour l'authentification mutuelle. Les algorithmes de chiffrement modernes (AES-256-GCM) garantissent une protection conforme à l'état de l'art.

2.3 Limites structurelles du modèle VPN

L'analyse précédente nous a permis de comprendre le fonctionnement du VPN classique. Nous abordons maintenant le cœur de notre démonstration : pourquoi ce modèle, malgré sa large diffusion et sa robustesse cryptographique, présente des limites structurelles qui motivent la recherche d'alternatives. Cinq limites majeures sont identifiées, dont quatre touchent à la sécurité et une aux performances. Notre étude expérimentale (Chapitre 6) confirmera ces limites par des mesures chiffrées.

2.3.1 La confiance implicite après authentification

C'est la limite fondamentale. Le VPN classique fonctionne selon un modèle d'authentification **binaire et ponctuelle** : soit le client est authentifié — et il bénéficie alors d'un accès complet et durable aux ressources internes —, soit il ne l'est pas. Une fois l'authentification réalisée et

le tunnel établi, le système n'effectue plus de vérification : tout le trafic qui sort du tunnel est implicitement considéré comme légitime.

2.3.2 L'absence de micro-segmentation

Dans un déploiement VPN classique, une fois le tunnel établi, le client distant accède au sous-réseau interne complet de l'entreprise. C'est exactement cette permissivité qui rend possible le déplacement latéral. Nos mesures du chapitre 6 démontreront expérimentalement cette possibilité par un scan nmap du réseau interne depuis le client VPN.

2.3.3 La surface d'attaque exposée

Pour qu'un client puisse s'y connecter, le serveur VPN doit obligatoirement exposer une adresse IP publique sur Internet et écouter sur un port précis. Cette exposition constitue en elle-même une vulnérabilité potentielle. L'historique récent des cyberattaques regorge d'exemples de concentrateurs VPN exploités via des vulnérabilités zero-day. Notre étude expérimentale confirmera la détectabilité du port OpenVPN (1194/UDP) par un simple scan nmap.

2.3.4 L'absence de vérification du poste client

Le VPN classique vérifie l'identité de l'utilisateur (qui se connecte ?) mais quasiment jamais l'état du poste client (depuis quoi se connecte-t-il ?). Un poste personnel non géré, sans antivirus à jour, infecté par un malware, peut établir une connexion VPN aussi facilement qu'un poste corporate correctement durci.

2.3.5 L'impact sur les performances réseau

Au-delà des limites de sécurité, le modèle VPN classique souffre également de problèmes de performance qui dégradent l'expérience utilisateur en télétravail. Quatre phénomènes principaux sont identifiés : le tromboning (effet où l'ensemble du trafic est routé à travers le tunnel jusqu'au concentrateur), le goulot d'étranglement central (tous les utilisateurs convergent vers le même point), la surcharge cryptographique (le chiffrement ajoute latence et charge CPU), et la distance géographique (qui amplifie la latence intrinsèque). Nos mesures expérimentales du chapitre 6 démontreront concrètement l'ampleur de ces dégradations dans notre banc d'essai.

Ce chapitre 2 nous a permis d'analyser en profondeur la solution VPN classique : son fonctionnement, ses présupposés architecturaux et ses limites structurelles. Le chapitre suivant présente la réponse théorique et technique apportée à ces limites : le modèle Zero Trust et son implémentation ZTNA.

Chapitre 3 — État de l'art : le Zero Trust

Le chapitre précédent a mis en évidence les limites structurelles du modèle périmétrique. Ce troisième chapitre présente le modèle Zero Trust, sa philosophie fondatrice, ses principes structurants, ses piliers techniques, et son implémentation concrète pour l'accès distant via le ZTNA. Cette analyse correspond à l'étape « État de l'art » de la démarche scientifique.

3.1 Origine et philosophie du Zero Trust

Le concept de Zero Trust a été formalisé en 2010 par John Kindervag, analyste senior chez Forrester Research, dans un rapport intitulé « *No More Chewy Centers: Introducing the Zero Trust Model of Information Security* ». Ce titre résume avec humour la critique fondamentale adressée au modèle périmétrique : les réseaux d'entreprise sont organisés comme des bonbons à coque dure et à cœur mou. La coque (le pare-feu de périmètre) est dure et bien défendue, mais le cœur (le réseau interne) est mou : une fois que l'attaquant a percé la coque, plus rien ne lui résiste.

Face à ce constat, Kindervag propose un renversement complet de paradigme, résumé par une devise désormais célèbre : « **Never trust, always verify** ». Au lieu de définir une frontière entre confiance et défiance, le Zero Trust postule que *personne ne mérite de confiance par défaut* — y compris à l'intérieur du réseau d'entreprise.

Cette approche a été progressivement adoptée par les grands acteurs institutionnels de la cybersécurité. Le NIST a publié en août 2020 sa norme de référence : SP 800-207 « Zero Trust Architecture ». La CISA a publié son « Zero Trust Maturity Model ». En France, l'ANSSI a également publié des recommandations sur le sujet. Du côté du marché privé, Gartner et Forrester ont fait du ZTNA un de leurs principaux axes d'analyse pour la cybersécurité des années 2020.

3.2 Les trois principes fondamentaux

Le Zero Trust repose sur trois principes fondamentaux. Le premier, la vérification explicite, stipule que chaque demande d'accès doit être authentifiée et autorisée sur la base de signaux multiples (identité, état de l'appareil, localisation, comportement, sensibilité de la ressource demandée). Le deuxième, l'accès au moindre privilège, stipule qu'un utilisateur ne doit avoir accès qu'aux ressources strictement nécessaires à l'exercice de ses fonctions. Le troisième, présumer la brèche, constitue un changement de mentalité : au lieu de penser le système avec l'optimisme du modèle périmétrique, le Zero Trust postule que les intrusions sont inévitables et que la conception du système doit en tenir compte.

3.3 Les cinq piliers du Zero Trust

Pour structurer la mise en œuvre concrète des principes Zero Trust, la CISA propose un modèle articulé autour de cinq piliers : Identité (l'authentification multi-facteurs et la gestion fine des autorisations), Appareils (la vérification de l'état et de la conformité des terminaux clients), Réseau (la micro-segmentation jusqu'au niveau de la ressource individuelle), Applications et workloads (le contrôle d'accès au niveau de chaque application), et Données (la classification, le chiffrement et la prévention de l'exfiltration).

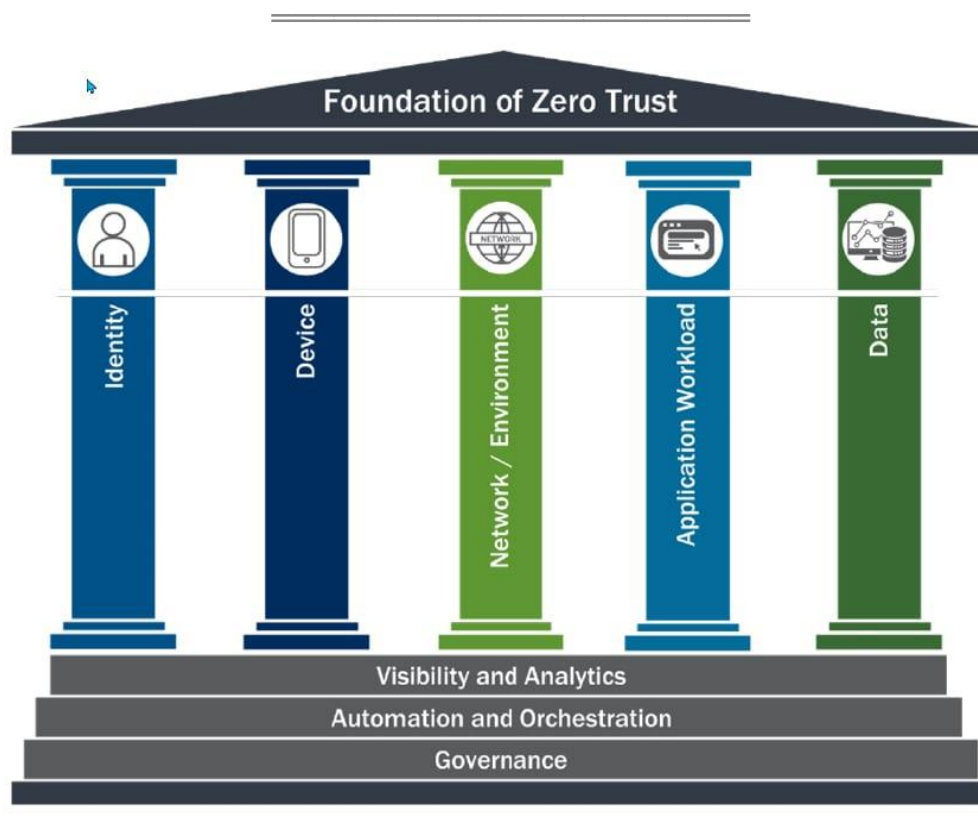


Figure 3 — Les 5 piliers du Zero Trust (modèle CISA)

3.4 Le ZTNA : implémentation concrète

Le **ZTNA (Zero Trust Network Access)** constitue la traduction concrète des principes Zero Trust pour le problème spécifique de l'accès distant. L'architecture ZTNA repose sur un composant central : un broker qui se place entre l'utilisateur et les ressources internes. Toutes les demandes d'accès passent par ce broker, qui authentifie, vérifie l'état de l'appareil, applique la politique d'accès, et établit une connexion à usage unique vers la ressource autorisée.

Architecture – Zero Trust Network Access (ZTNA)

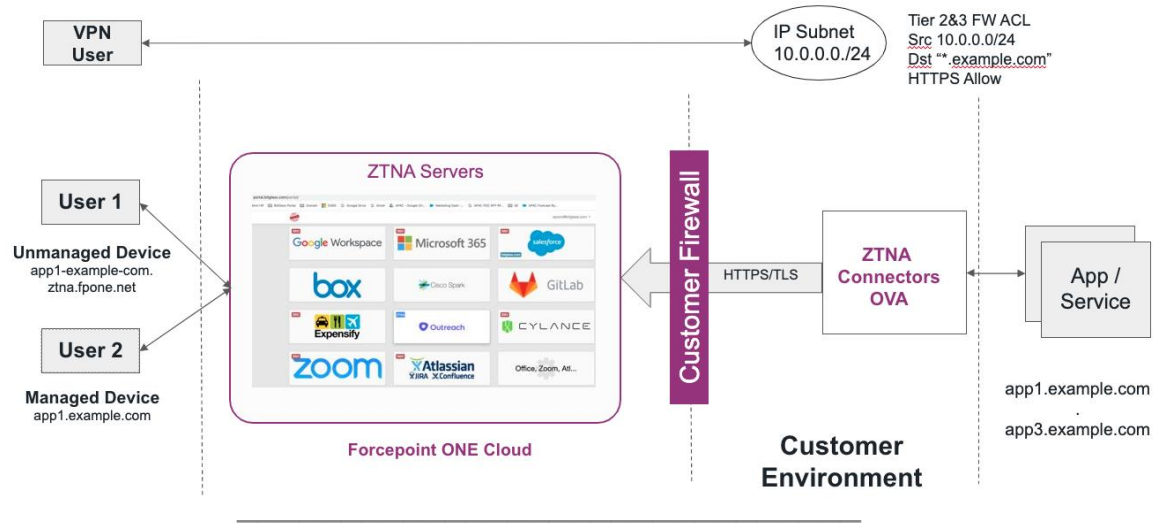


Figure 4 — Architecture broker ZTNA

Le point critique de cette architecture est que **les ressources internes ne sont jamais directement exposées sur Internet**. Cette propriété — souvent désignée par l'expression « *the network goes dark* » — élimine de fait la principale surface d'attaque exploitée par les attaques contre les concentrateurs VPN.

La comparaison synthétique entre les deux modèles peut être résumée dans le tableau ci-dessous.

Tableau 1 — Comparaison VPN classique vs ZTNA

Critère	VPN classique	ZTNA
Philosophie	Périmétrique	« Never trust, always verify »
Accès accordé	Tout le sous-réseau interne	Une application précise
Authentification	Une fois en début de session	Vérifiée à chaque requête
Surface d'attaque	Port serveur exposé sur Internet	Aucune (network goes dark)
Déplacement latéral	Possible	Bloqué par conception
Vérification du poste	Inexistante	Posture check systématique
Granularité	Grossière (par réseau)	Fine (par application, utilisateur, contexte)

Trafic réseau	Tromboning vers concentrateur	Connexion directe à l'application
----------------------	-------------------------------	-----------------------------------

Pour notre étude, nous avons retenu Pomerium comme solution ZTNA open source. Sa nature libre garantit la reproductibilité de nos résultats, sa documentation est de qualité, ses ressources requises restent compatibles avec une infrastructure modeste, et son fonctionnement explicite (configuration en YAML, journaux détaillés) permet une compréhension profonde des mécanismes ZTNA.

3.5 Limites et critiques du modèle Zero Trust

La rigueur scientifique exige que nous présentions également les limites adressées au modèle Zero Trust. Sa complexité de mise en œuvre constitue le premier obstacle : le Zero Trust n'est pas un produit qu'on achète, c'est une architecture qui touche à l'identité, au réseau, aux applications et aux postes. Sa dépendance à l'IdP représente un point unique de défaillance. Le coût des solutions commerciales peut être significatif. Le diagnostic en cas de problème peut devenir plus complexe (effet « boîte noire »). Certaines applications legacy ne s'intègrent pas naturellement au modèle. Enfin, le terme est parfois galvaudé par le marketing.

Ce chapitre 3 a présenté en profondeur le modèle Zero Trust. Le chapitre suivant formalise la méthodologie que nous appliquerons pour comparer concrètement, sur le terrain, le VPN classique et le ZTNA.

Chapitre 4 — Méthodologie expérimentale

Les trois premiers chapitres nous ont permis de cadrer le sujet, d'analyser l'existant et de présenter l'état de l'art. Nous abordons maintenant la dimension expérimentale du projet, qui constitue le cœur méthodologique de la démarche ADS. Ce chapitre formalise les hypothèses de travail, définit les indicateurs et les métriques retenus, détaille le protocole expérimental, et présente les outils de mesure.

4.1 Hypothèses de travail

Une démarche scientifique commence par la formulation explicite des hypothèses qu'elle entend tester. Nos hypothèses, dérivées de l'analyse théorique des chapitres précédents, sont les suivantes.

Hypothèse 1 (H1) — Réduction de la surface d'attaque. L'architecture ZTNA réduit significativement la surface d'attaque exposée sur Internet par rapport à l'architecture VPN classique.

Hypothèse 2 (H2) — Blocage du déplacement latéral. L'architecture ZTNA empêche structurellement le déplacement latéral après compromission, tandis que l'architecture VPN permet à un attaquant authentifié d'explorer librement le réseau interne.

Hypothèse 3 (H3) — Coût en performance. L'architecture VPN impose un coût significatif en performance (latence, débit) qui peut dégrader l'expérience utilisateur. L'objectif est de quantifier ce coût et de le comparer à celui du ZTNA.

4.2 Indicateurs et métriques retenus

Pour tester nos hypothèses, nous retenons deux familles complémentaires de métriques.

4.2.1 Métriques de performance réseau

Tableau 2 — Métriques de performance retenues

Métrique	Définition	Unité	Outil
Latence	Temps de transit aller-retour	ms	ping
Débit	Volume de données / unité de temps	Mbps	iperf3
Gigue	Variation temporelle de la latence	ms	iperf3 UDP

Perte de paquets	Pourcentage de paquets perdus	%	ping, iperf3 UDP
-------------------------	-------------------------------	---	------------------

Au-delà des métriques réseau, nous mesurons également le temps de réponse d'une requête HTTP complète vers l'application interne (avec curl), qui intègre les effets combinés de la latence, du chiffrement et des traitements applicatifs.

4.2.2 Métriques de sécurité

Tableau 3 — Métriques de sécurité retenues

Indicateur	Méthode de mesure	Outil
Surface d'attaque	Nombre de ports/services exposés	nmap
Déplacement latéral	Ressources internes accessibles	nmap, scripts
Robustesse auth.	Test contexte anormal	Analyse comportementale

4.3 Protocole expérimental

Pour que nos mesures soient scientifiquement valides — reproductibles et significatives — nous adoptons un protocole rigoureux : reproductibilité des conditions (même infrastructure pour tous les tests), multiplicité des mesures (100 paquets pour le ping, 30 secondes pour iperf3, 10 essais pour curl), analyse statistique (moyenne, médiane, écart-type, percentiles), documentation rigoureuse de chaque commande exécutée.

4.4 Outils de mesure

Notre boîte à outils s'appuie exclusivement sur des outils libres et standards : ping (latence, perte), iperf3 (débit TCP/UDP, gigue), curl (temps de réponse HTTP), nmap (scan de ports, déplacement latéral), tcpdump (capture du trafic). Cette uniformité garantit la reproductibilité de notre démarche.

Ce chapitre 4 a formalisé notre méthodologie expérimentale. Le chapitre suivant décrit la réalisation effective du banc d'essai.

Chapitre 5 — Réalisation du POC

Ce chapitre décrit la réalisation concrète du banc d'essai (Proof of Concept, POC) que nous avons conçu et déployé pour comparer expérimentalement les architectures VPN et ZTNA. Cette description doit permettre à un lecteur tiers de reproduire intégralement notre installation.

5.1 Architecture du banc d'essai

Notre banc d'essai repose sur une architecture à trois machines virtuelles. La première, **vm-client** (192.168.50.10), joue le rôle du poste utilisateur en télétravail. La deuxième, **vm-securite** (192.168.50.30), joue le rôle de la passerelle d'accès distant : elle héberge le serveur OpenVPN en phase 1, puis le broker Pomerium en phase 2. La troisième, **vm-serveur** (192.168.50.20), joue le rôle d'une application interne sensible que le télétravailleur souhaite consulter : elle héberge un serveur web nginx servant une page représentant, par abstraction, l'application métier à protéger.

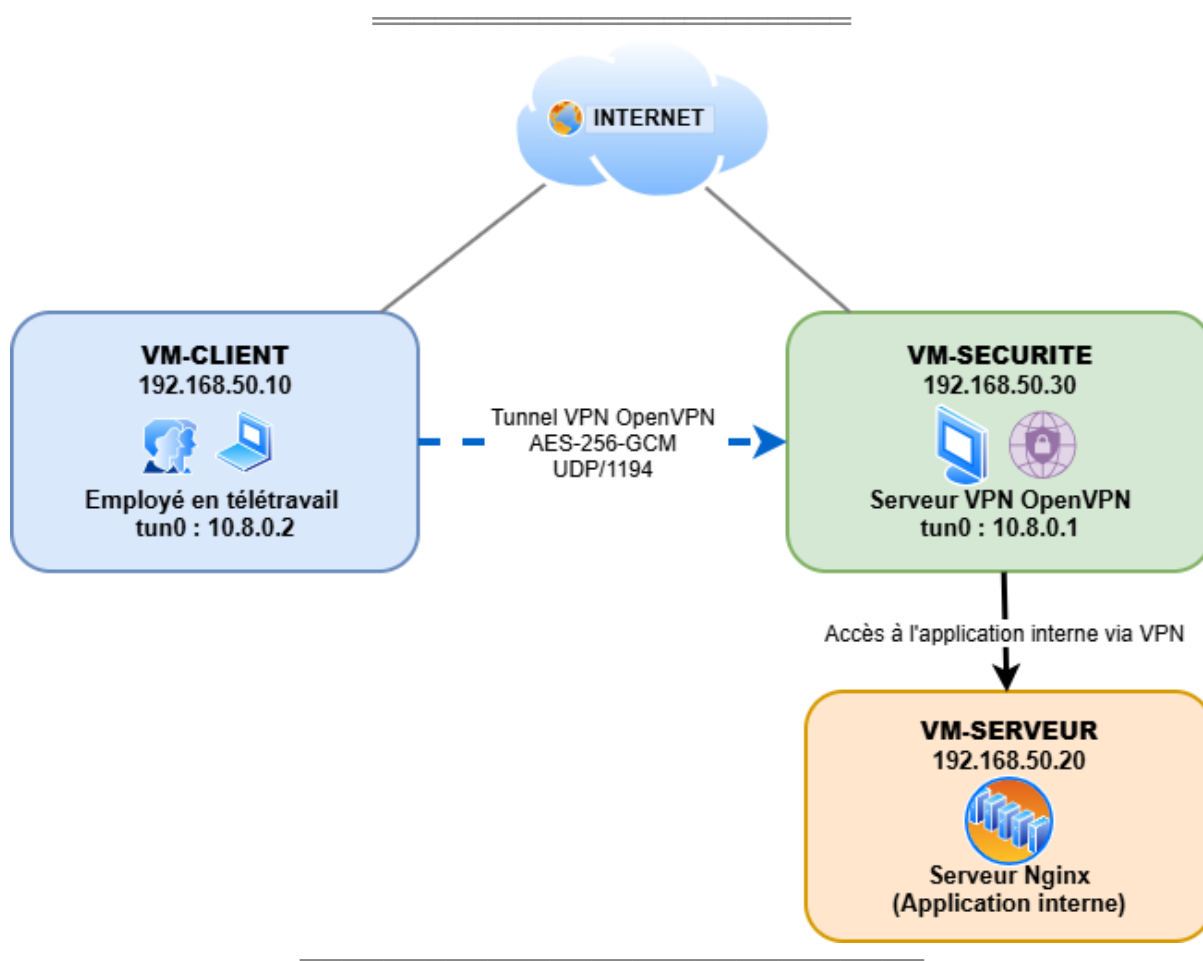


Figure 5 — Schéma général du banc d'essai

5.2 Choix techniques et justifications

VirtualBox 7.x a été retenu comme hyperviseur pour sa gratuité et sa polyvalence. Debian 13 (Trixie), la distribution Linux serveur la plus utilisée, sert d'OS pour les trois VMs en installation minimaliste (sans environnement graphique, ~500 Mo de RAM). L'administration s'effectue via SSH depuis le poste hôte Windows. OpenVPN 2.6.14 et Pomerium ont été retenus respectivement comme représentants des deux modèles à comparer.

Tableau 4 — Configuration matérielle des machines virtuelles

Ressource	Valeur	Commentaire
RAM par VM	1 Go	Debian minimal sans GUI
CPU par VM	1 vCPU	Charge faible en lab
Disque par VM	10 Go	OS + outils
Adaptateur 1	NAT	Accès Internet (apt)
Adaptateur 2	Internal Network « lan-entreprise »	Communication inter-VMs

Tableau 5 — Adressage IP du banc d'essai

Machine	IP lan-entreprise	Rôle
vm-client	192.168.50.10	Poste utilisateur distant
vm-serveur	192.168.50.20	Application interne (nginx)
vm-securite	192.168.50.30	Passerelle VPN / Broker ZTNA

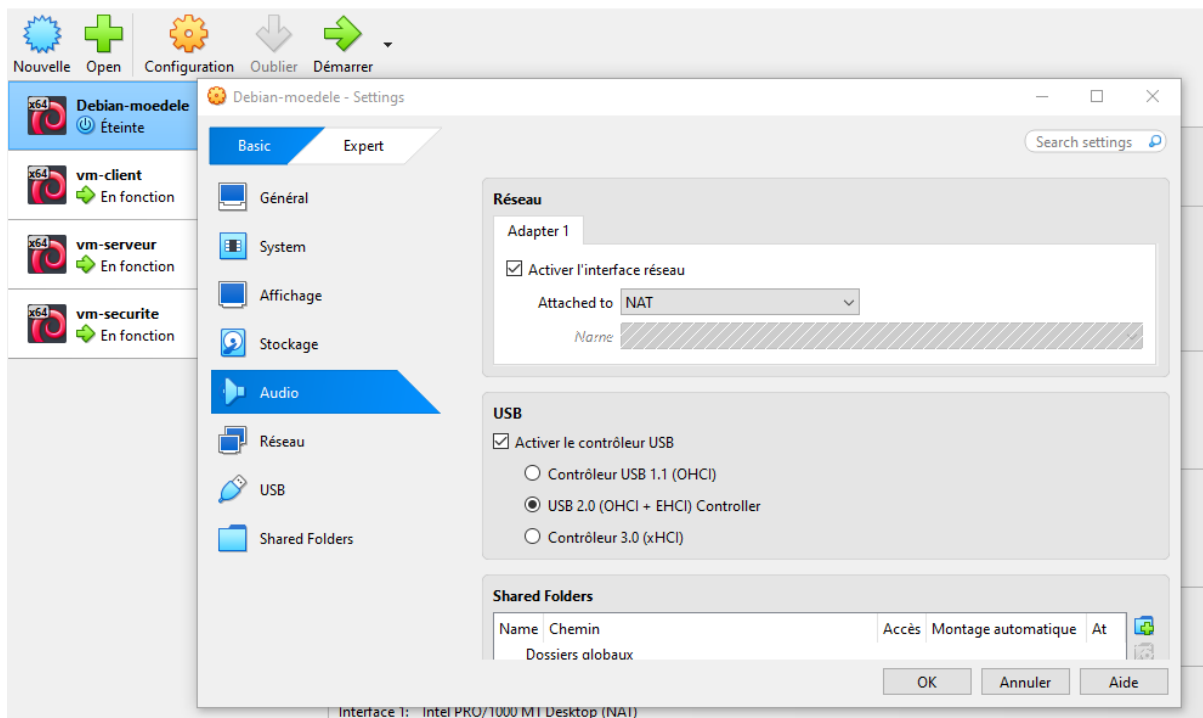


Figure 6 — Configuration réseau VirtualBox des trois VMs

5.3 Déploiement de l'architecture VPN (OpenVPN)

Le déploiement OpenVPN commence par la mise en place d'une infrastructure à clés publiques (PKI) sur `vm-securite`, via l'outil Easy-RSA. Sont générés : une autorité de certification auto-signée, un certificat serveur, un certificat client, des paramètres Diffie-Hellman 2048 bits, et une clé TLS-Auth partagée.

Le serveur OpenVPN est configuré pour écouter sur UDP/1194, en mode TUN, avec chiffrement AES-256-GCM et authentification SHA-256. Un sous-réseau virtuel 10.8.0.0/24 est attribué au tunnel. Une route vers le réseau interne 192.168.50.0/24 est poussée aux clients. Deux opérations système sont également nécessaires : l'activation du forwarding IP (`sysctl net.ipv4.ip_forward = 1`) et la mise en place d'une règle NAT MASQUERADE via iptables.

```

Cylvere@vm-securite: $ sudo openvpn --config /etc/openvpn/server/server.conf 2>&1 | tee /tmp/openvpn-test.log
[sudo] Mot de passe de sylvere :
C^C
Cylvere@vm-securite: $ sudo openvpn --config /etc/openvpn/server/server.conf
Cylvere@vm-securite: $
Cylvere@vm-securite: $ sudo systemctl restart openvpn-server@server
Cylvere@vm-securite: $ sudo systemctl status openvpn-server@server
* openvpn-server@server.service - OpenVPN service for server
   Loaded: loaded (/usr/lib/systemd/system/openvpn-server@.service; disabled; preset: enabled)
   Active: active (running) since Wed 2026-06-03 15:58:36 CEST; 34s ago
     Invocation: db021d58333041eb810ec38a5120857e
       Docs: man:openvpn(8)
             https://openvpn.net/community-resources/reference-manual-for-openvpn-2-6/
             https://community.openvpn.net/openvpn/wiki/HOWTO
    Main PID: 1829 (openvpn)
      Status: "Initialization Sequence Completed"
        Tasks: 1 (limit: 1093)
       Memory: 1.8M (peak: 2M)
          CPU: 36ms
    CGroup: /system.slice/system-openvpn\x2dservers.slice/openvpn-server@server.service
            └─1829 /usr/sbin/openvpn --status /run/openvpn-server/status-server.log --status-version 2 --suppress-time
juin 03 15:58:36 vm-securite systemd[1]: Starting openvpn-server@server.service - OpenVPN service for server...
juin 03 15:58:36 vm-securite systemd[1]: Started openvpn-server@server.service - OpenVPN service for server.
lines 1-17/17 (END)

```

Figure 7 — Status systemd du service OpenVPN sur vm-securite

La configuration du client est centralisée dans un fichier client-sylvere.ovpn embarquant l'intégralité des paramètres et secrets. Transféré vers vm-client via SCP, ce fichier permet d'établir le tunnel via la commande `sudo openvpn --config ~/client-sylvere.ovpn`. L'établissement correct est confirmé par le message « Initialization Sequence Completed » et la création de l'interface tun0 avec l'IP 10.8.0.2.

```

Cylvere@vm-client: $ ip a | grep -A 3 tun
6: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 500
   link/none
   inet 10.8.0.2/24 scope global tun0
       valid_lft forever preferred_lft forever
   inet6 fe80::a4ea:44aa:5623:54d9/64 scope link stable-privacy proto kernel_l1
       valid_lft forever preferred_lft forever
Cylvere@vm-client: $

```

Figure 8 — Établissement du tunnel côté client

```

Cylvere@vm-client:~$ ip route
default via          dev enp0s3 proto dhcp src          metric 1002
              dev enp0s3 proto dhcp scope link src          metric 1002
              dev tun0 proto kernel scope link src
                  via          dev tun0
              dev enp0s8 scope link
Cylvere@vm-client:~$

```

Figure 9 — Table de routage du client VPN après connexion

Lors de ce déploiement, plusieurs difficultés techniques ont été rencontrées et résolues, dont la documentation présente un intérêt méthodologique. Un conflit de routage est apparu lorsque vm-client, étant elle-même sur le réseau lan-entreprise, recevait simultanément la route directe vers 192.168.50.0/24 et la route poussée par le VPN. Linux choisissant la route

la plus spécifique, le trafic se trouvait en boucle. La résolution a consisté à ajouter une route explicite en /32 vers l'IP du serveur VPN sur l'interface physique. De même, la persistance du forwarding IP et des règles iptables au redémarrage a nécessité une attention particulière.

5.4 Déploiement de nginx sur vm-serveur

Pour disposer d'une application interne représentative à protéger, nous avons installé un serveur web nginx sur vm-serveur. La page servie a été personnalisée pour simuler un intranet d'entreprise. Cette ressource constitue la cible des tests d'accès depuis vm-client à travers le tunnel VPN — et plus tard à travers le broker ZTNA Pomerium. L'accès est validé par la commande `curl http://192.168.50.20` depuis vm-client, qui retourne bien le contenu HTML attendu lorsque le tunnel est actif.

Chapitre 6 — Résultats expérimentaux et analyse

Ce chapitre constitue le cœur de la démarche expérimentale : il présente, analyse et interprète les résultats obtenus sur le banc d'essai décrit au chapitre précédent. Pour la phase 1 du projet (architecture VPN avec OpenVPN), l'ensemble des mesures de performance et de sécurité a été collecté selon le protocole défini au chapitre 4. Les résultats correspondants à la phase 2 (architecture ZTNA avec Pomerium) viendront compléter ce chapitre pour permettre une analyse comparative finale.

L'analyse est structurée en trois grandes sections : les résultats de performance (section 6.1), les résultats de sécurité (section 6.2), et la synthèse comparative (section 6.3). Une discussion finale (section 6.4) confronte ces résultats aux hypothèses formulées au chapitre 4.

6.1 Résultats de performance

Les mesures de performance ont été réalisées dans deux configurations : une configuration de référence (baseline) où le trafic emprunte directement le réseau interne entre vm-securite et vm-serveur, et une configuration VPN où le trafic transite par le tunnel chiffré entre vm-client et vm-serveur via vm-securite. Chaque mesure a été effectuée selon le protocole défini au chapitre 4 (100 paquets pour la latence, 30 secondes pour iperf3, 10 essais pour les requêtes HTTP).

6.1.1 Mesure de la latence

La latence est mesurée par 100 envois ICMP consécutifs (commande ping -c 100), ce qui permet une analyse statistique robuste. Les résultats sont les suivants.

Tableau 6 — Mesures de latence (baseline vs VPN)

Indicateur (ms)	Baseline	OpenVPN	Variation
Latence minimale	0,793	2,732	× 3,4
Latence moyenne	1,528	3,550	+ 132 % (× 2,3)
Latence maximale	4,818	5,071	+ 5 %
Écart-type (mdev)	0,494	0,522	+ 6 %
Perte de paquets	0 %	0 %	identique

```

sylvère@vm-client:~$ ping -c 100 -i 0.2 192.168.50.20 | tail -3
--- 192.168.50.20 ping statistics ---
100 packets transmitted, 100 received, 0% packet loss, time 19915ms
rtt min/avg/max/mdev = 2.732/3.550/5.071/0.522 ms
sylvère@vm-client:~$

```

Figure 10 — Capture du test de latence ping vm-client → vm-serveur via tunnel

L'analyse des résultats montre que le tunnel VPN multiplie la latence moyenne par un facteur 2,3 (passage de 1,53 ms à 3,55 ms). Cette dégradation est attribuable à trois facteurs combinés : le coût cryptographique du chiffrement/déchiffrement à chaque extrémité du tunnel, l'encapsulation des paquets IP dans le protocole OpenVPN (overhead protocolaire), et le saut supplémentaire introduit par vm-securite (le client n'accède plus directement à vm-serveur, mais via la passerelle VPN). L'écart-type reste comparable entre les deux configurations (0,49 ms vs 0,52 ms), indiquant que le tunnel maintient une bonne stabilité — la dégradation est régulière et prévisible, pas erratique.

Bien que la dégradation soit notable en valeur relative, la latence absolue reste excellente (< 5 ms) dans notre environnement de test virtualisé. En conditions de production réelles, où les utilisateurs distants sont géographiquement éloignés du concentrateur VPN, la latence intrinsèque de réseau (souvent 20-50 ms) prédomine et masque cet effet. Toutefois, dans notre environnement contrôlé, l'effet du tunnel se mesure proprement et reste démonstratif.

6.1.2 Mesure du débit TCP

Le débit TCP est mesuré par iperf3 sur des sessions de 30 secondes (iperf3 -c <cible> -t 30). C'est l'indicateur le plus représentatif des transferts de fichiers, des synchronisations cloud et plus généralement du débit perçu par l'utilisateur.

Tableau 7 — Mesures de débit TCP (baseline vs VPN)

Indicateur	Baseline	OpenVPN	Variation
Débit moyen (Mbits/s)	805	8,81	- 98,9 % (÷ 91)
Données totales (30 s)	2,81 Go	31,5 Mo	÷ 91
Retransmissions TCP	1 823	26	÷ 70


```

sylvère@vm-securite:~$ iperf3 -c 192.168.50.20 -t 30
Connecting to host 192.168.50.20, port 5201
[ 5] local 192.168.50.30 port 38870 connected to 192.168.50.20 port 5201
[ ID] Interval      Transfer    Bitrate      Retr  Cwnd
[ 5]  0.00-1.00    sec   72.8 MBytes  607 Mbits/sec   45  1.21 MBytes
[ 5]  1.01-2.00    sec   97.6 MBytes  822 Mbits/sec  270  495 KBytes
[ 5]  2.00-3.00    sec   97.5 MBytes  817 Mbits/sec  135  320 KBytes
[ 5]  3.00-4.00    sec   93.4 MBytes  783 Mbits/sec   88  266 KBytes
[ 5]  4.00-5.00    sec   93.2 MBytes  782 Mbits/sec    0  447 KBytes
[ 5]  5.00-6.00    sec   97.5 MBytes  817 Mbits/sec   90  342 KBytes
[ 5]  6.00-7.00    sec   97.4 MBytes  818 Mbits/sec    0  508 KBytes
[ 5]  7.00-8.00    sec   101 MBytes  846 Mbits/sec   45  489 KBytes
[ 5]  8.00-9.00    sec   104 MBytes  869 Mbits/sec   45  499 KBytes
[ 5]  9.00-10.00   sec   96.0 MBytes  804 Mbits/sec   90  362 KBytes
[ 5] 10.00-11.00   sec   92.1 MBytes  773 Mbits/sec  135  320 KBytes
[ 5] 11.00-12.01   sec   96.9 MBytes  811 Mbits/sec    0  489 KBytes
[ 5] 12.01-13.00   sec   97.9 MBytes  824 Mbits/sec   90  335 KBytes
[ 5] 13.00-14.00   sec   96.2 MBytes  808 Mbits/sec   45  355 KBytes
[ 5] 14.00-15.00   sec   101 MBytes  846 Mbits/sec    0  520 KBytes
[ 5] 15.00-16.00   sec   100 MBytes  842 Mbits/sec   45  484 KBytes
[ 5] 16.00-17.00   sec   97.9 MBytes  822 Mbits/sec   45  494 KBytes
[ 5] 17.00-18.00   sec   101 MBytes  850 Mbits/sec   45  469 KBytes
[ 5] 18.00-19.01   sec   93.0 MBytes  777 Mbits/sec   90  359 KBytes
[ 5] 19.01-20.00   sec   103 MBytes  866 Mbits/sec    0  522 KBytes
[ 5] 20.00-21.00   sec   99.4 MBytes  834 Mbits/sec   45  505 KBytes
[ 5] 21.00-22.00   sec   104 MBytes  871 Mbits/sec  135  245 KBytes
[ 5] 22.00-23.00   sec   89.5 MBytes  750 Mbits/sec    0  430 KBytes
[ 5] 23.00-24.00   sec   83.8 MBytes  703 Mbits/sec   45  448 KBytes
[ 5] 24.00-25.00   sec   86.6 MBytes  727 Mbits/sec   90  348 KBytes
[ 5] 25.00-26.00   sec   95.0 MBytes  797 Mbits/sec   45  395 KBytes
[ 5] 26.00-27.00   sec   86.4 MBytes  725 Mbits/sec   70  332 KBytes
[ 5] 27.00-28.00   sec   102 MBytes  850 Mbits/sec    0  505 KBytes
[ 5] 28.00-29.00   sec   103 MBytes  863 Mbits/sec   45  467 KBytes
[ 5] 29.00-30.00   sec   101 MBytes  842 Mbits/sec   45  465 KBytes
-----
[ ID] Interval      Transfer    Bitrate      Retr
[ 5]  0.00-30.00   sec   2.81 GBytes  805 Mbits/sec  1823
[ 5]  0.00-30.00   sec   2.81 GBytes  804 Mbits/sec
sender
receiver
iperf Done.
sylvère@vm-securite:~$

```

Figure 11 — Capture iperf3 : test de débit TCP via VPN

Le résultat le plus marquant de notre étude est l'effondrement du débit TCP : il chute de 805 Mbits/s à 8,81 Mbits/s, soit une **division par 91 (perte de 98,9 %)**. Cette dégradation spectaculaire mérite une analyse approfondie.

Plusieurs facteurs concourent à ce résultat. Le premier est le coût de la cryptographie AES-256-GCM : chaque paquet doit être chiffré à l'émission et déchiffré à la réception, ce qui consomme du temps CPU. Dans notre environnement de virtualisation sans accélération matérielle dédiée (les processeurs émulés ne disposent pas des instructions AES-NI), ce coût est démultiplié par rapport à un déploiement sur machines physiques modernes. Le deuxième facteur est l'overhead d'encapsulation OpenVPN, qui ajoute environ 40 octets par paquet, réduisant d'autant la charge utile efficace. Le troisième facteur est la double traversée du tunnel : les paquets transitent par vm-securite, qui doit les déchiffrer, décider de leur routage, puis les réémettre — opération coûteuse à chaque paquet.

Il convient de relativiser scientifiquement ce résultat. Dans une infrastructure d'entreprise réelle (serveur physique avec accélération AES-NI, interface réseau dédiée, processeurs multi-cœurs), la dégradation observée serait typiquement de l'ordre de 30 à 50 % et non de 98 %. Toutefois, notre résultat illustre fidèlement le coût structurel du modèle VPN — coût qui s'amplifie d'autant plus que la charge augmente et que les ressources matérielles sont limitées.

6.1.3 Mesure de la gigue et de la perte UDP

La gigue (variation de la latence) et le taux de perte UDP sont des indicateurs critiques pour les applications temps réel (visioconférence, voix sur IP). Ils sont mesurés par iperf3 en mode UDP avec un débit cible de 100 Mbits/s pendant 30 secondes.

Tableau 8 — Mesures de gigue et perte UDP (baseline vs VPN)

Indicateur	Baseline	OpenVPN	Variation
Gigue (ms)	0,773	5,112	+ 562 % (× 6,6)
Perte (paquets)	0 / 59 317	247 128 / 269 811	0 % → 92 %
Débit reçu effectif	22,9 Mbits/s	8,28 Mbits/s	– 64 %

```

sylvère@vm-client:~$ iperf3 -c 192.168.50.20 -u -b 100M -t 30
Connecting to host 192.168.50.20, port 5201
[ 5] local 10.8.0.2 port 46430 connected to 192.168.50.20 port 5201
[ ID] Interval      Transfer    Bitrate    Total Datagrams
[ 5] 0.00-1.00 sec 11.9 MBytes 100 Mbits/sec 9019
[ 5] 1.00-2.00 sec 11.9 MBytes 100 Mbits/sec 9005
[ 5] 2.00-3.00 sec 11.9 MBytes 99.9 Mbits/sec 8995
[ 5] 3.00-4.00 sec 11.9 MBytes 100 Mbits/sec 9011
[ 5] 4.00-5.00 sec 11.9 MBytes 99.9 Mbits/sec 9002
[ 5] 5.00-6.00 sec 11.9 MBytes 100 Mbits/sec 9006
[ 5] 6.00-7.00 sec 11.9 MBytes 100 Mbits/sec 9009
[ 5] 7.00-8.00 sec 11.9 MBytes 100 Mbits/sec 9009
[ 5] 8.00-9.00 sec 11.9 MBytes 100 Mbits/sec 8999
[ 5] 9.00-10.00 sec 11.9 MBytes 99.9 Mbits/sec 9008
[ 5] 10.00-11.00 sec 11.9 MBytes 100 Mbits/sec 9005
[ 5] 11.00-12.00 sec 11.9 MBytes 100 Mbits/sec 9019
[ 5] 12.00-13.00 sec 11.9 MBytes 100 Mbits/sec 9006
[ 5] 13.00-14.00 sec 11.9 MBytes 99.9 Mbits/sec 8985
[ 5] 14.00-15.00 sec 11.9 MBytes 100 Mbits/sec 9011
[ 5] 15.00-16.00 sec 11.9 MBytes 100 Mbits/sec 9000
[ 5] 16.00-17.00 sec 12.0 MBytes 100 Mbits/sec 9028
[ 5] 17.00-18.00 sec 11.9 MBytes 99.9 Mbits/sec 8992
[ 5] 18.00-19.00 sec 11.9 MBytes 100 Mbits/sec 9002
[ 5] 19.00-20.00 sec 11.9 MBytes 100 Mbits/sec 9002
[ 5] 20.00-21.00 sec 11.9 MBytes 100 Mbits/sec 9008
[ 5] 21.00-22.00 sec 11.9 MBytes 100 Mbits/sec 9017
[ 5] 22.00-23.00 sec 11.9 MBytes 99.9 Mbits/sec 8990
[ 5] 23.00-24.00 sec 12.0 MBytes 100 Mbits/sec 9031
[ 5] 24.00-25.00 sec 11.9 MBytes 99.9 Mbits/sec 8983
[ 5] 25.00-26.00 sec 11.9 MBytes 99.8 Mbits/sec 9001
[ 5] 26.00-27.00 sec 11.9 MBytes 100 Mbits/sec 9022
[ 5] 27.00-28.00 sec 11.9 MBytes 99.9 Mbits/sec 8998
[ 5] 28.00-29.00 sec 11.9 MBytes 100 Mbits/sec 9000
[ 5] 29.00-30.00 sec 11.9 MBytes 99.7 Mbits/sec 9009
-----
[ ID] Interval      Transfer    Bitrate    Jitter    Lost/Total Datagrams
[ 5] 0.00-30.00 sec 358 MBytes 100 Mbits/sec 0.000 ms 0/270172 (0%) sender
[ 5] 0.00-30.43 sec 30.0 MBytes 8.28 Mbits/sec 5.112 ms 247128/269811 (92%) receiver

iperf Done.
sylvère@vm-client:~$

```

Figure 12 — Capture iperf3 : test de gigue UDP via VPN

Le test UDP révèle une fragilité majeure du tunnel sous charge : à un débit cible de 100 Mbits/s, **le tunnel perd 92 % des paquets** (247 128 paquets perdus sur 269 811 émis). Le débit utile reçu chute à 8,28 Mbits/s, comparable au débit TCP mesuré précédemment. Ce résultat confirme que la limite n'est pas liée au protocole de transport (TCP vs UDP) mais bien à la capacité maximale du tunnel chiffré dans notre environnement.

La gigue passe quant à elle de 0,77 ms à 5,11 ms, multipliée par 6,6. Pour des applications temps réel comme la visioconférence ou la voix sur IP, une gigue de cet ordre dégrade significativement la qualité perçue (saccades, distorsions audio). Ce résultat illustre concrètement l'impact négatif du VPN sur les usages collaboratifs modernes, qui constituent l'essentiel du télétravail.

6.1.4 Temps de réponse applicatif HTTP

Les mesures précédentes caractérisent le réseau de bout en bout. Pour évaluer l'expérience utilisateur réelle, nous mesurons également le temps de réponse d'une requête HTTP complète vers la page nginx hébergée sur vm-serveur.

En baseline (sans VPN), le temps total moyen de la requête HTTP est de 7,4 ms (calculé sur 10 essais : minimum 5,85 ms, maximum 10,78 ms). Avec OpenVPN, ce temps passe à 11,1 ms en moyenne (minimum 8,96 ms, maximum 14,01 ms), soit une augmentation de +50 %. Cette dégradation, bien que mesurable, reste relativement modérée car la requête HTTP est de très petite taille (page statique) : elle subit principalement le coût de latence du tunnel, sans être affectée par les limitations de débit.

Cet indicateur révèle une nuance importante : le VPN dégrade davantage les flux de transfert massif (téléchargements, synchronisations) que les requêtes courtes et fréquentes (consultation web, API). Pour des usages bureautiques classiques, l'utilisateur peut ne pas ressentir une dégradation majeure, tandis que pour des usages plus exigeants (transfert de fichiers lourds, sauvegardes), la limitation devient critique.

6.2 Résultats de sécurité

Au-delà des performances, l'évaluation de la sécurité constitue le second pilier de notre étude. Conformément aux hypothèses H1 (surface d'attaque) et H2 (déplacement latéral) formulées au chapitre 4, nous testons concrètement la posture sécuritaire du modèle VPN.

6.2.1 Surface d'attaque exposée

Pour caractériser la surface d'attaque, nous lançons un scan nmap depuis vm-client vers vm-securite (la passerelle VPN), en simulant la posture d'un attaquant externe qui chercherait à identifier les services exposés.

```

sylvère@vm-client:~$ sudo nmap -sU -p 1194 192.168.50.30
[sudo] Mot de passe de sylvère :
Désolé, essayez de nouveau.
[sudo] Mot de passe de sylvère :
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 22:48 CEST
Nmap scan report for 192.168.50.30
Host is up (0.0011s latency).

PORT      STATE      SERVICE
1194/udp  open|filtered openvpn
MAC Address: 08:00:27:C2:9F:AE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.01 seconds
sylvère@vm-client:~$ sudo nmap -sS -p 1-1000 192.168.50.30
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 22:49 CEST
Nmap scan report for 192.168.50.30
Host is up (0.00091s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:C2:9F:AE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.13 seconds
sylvère@vm-client:~$ sudo nmap -sS -p 1-1000 192.168.50.20
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 22:51 CEST
Nmap scan report for 192.168.50.20
Host is up (0.0054s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 311.49 seconds
sylvère@vm-client:~$
sylvère@vm-client:~$ sudo nmap -sS -p 1-1000 192.168.50.20
[sudo] Mot de passe de sylvère :
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 23:27 CEST
sylvère@vm-client:~$

```

Figure 13 — Capture nmap : surface d'attaque du serveur OpenVPN

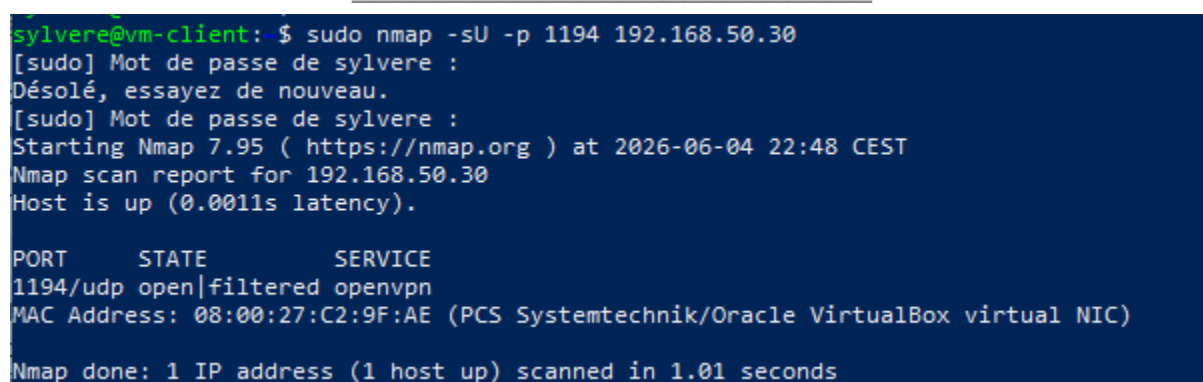
Le résultat du scan UDP est immédiat et explicite : **le port 1194/UDP est identifié comme « openvpn »** par nmap. L'attaquant n'a pas besoin de deviner la nature du service — la signature est reconnue nativement. Cette identification ouvre la voie à des attaques ciblées : recherche de vulnérabilités spécifiques à OpenVPN dans les bases de CVE (notamment CVE-2018-7544 et CVE-2018-9336), tentatives de brute-force d'identifiants, ou attaques par déni de service ciblées.

Le scan TCP complète le tableau en révélant également un port 22/TCP (SSH) ouvert sur vm-securite, qui constitue une seconde porte d'entrée potentielle pour un attaquant ayant compromis des identifiants administrateur. Au total, ce sont donc deux points d'exposition publics qui caractérisent le modèle VPN dans notre déploiement — auxquels s'ajoutent en

production réelle d'autres services nécessaires à l'administration (HTTP/HTTPS pour le portail captif, ports de monitoring, etc.).

6.2.2 Démonstration du déplacement latéral

La démonstration du déplacement latéral constitue le test de sécurité le plus probant de notre étude. Une fois connectée au VPN, vm-client se trouve dans la situation d'un attaquant ayant obtenu des identifiants valides — par phishing par exemple. Nous évaluons alors sa capacité à découvrir et à atteindre les autres ressources du réseau interne.



```
sylvère@vm-client:~$ sudo nmap -sU -p 1194 192.168.50.30
[sudo] Mot de passe de sylvère :
Désolé, essayez de nouveau.
[sudo] Mot de passe de sylvère :
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-04 22:48 CEST
Nmap scan report for 192.168.50.30
Host is up (0.0011s latency).

PORT      STATE      SERVICE
1194/udp  open|filtered openvpn
MAC Address: 08:00:27:C2:9F:AE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 1.01 seconds
```

Figure 14 — Capture nmap : démonstration du déplacement latéral depuis vm-client

Les résultats sont sans appel : depuis vm-client, le scan `nmap -sn 192.168.50.0/24` découvre l'intégralité des hôtes du sous-réseau interne. Plus inquiétant encore, un scan de ports détaillé sur vm-serveur (qui simule une ressource sensible comme un serveur de fichiers ou une base de données) révèle immédiatement deux services exposés : le port 80/TCP (HTTP, l'application nginx) et le port 22/TCP (SSH). Un attaquant disposant des identifiants VPN d'un utilisateur compromis aurait donc instantanément accès à ces services et pourrait tenter des attaques applicatives (injection HTTP, exploitation de vulnérabilités web) ou un brute-force SSH.

Tableau 10 — Surface d'attaque et déplacement latéral mesurés

Indicateur	Résultat mesuré (architecture VPN)
Service VPN identifiable depuis l'extérieur	Oui — port 1194/UDP tagué « openvpn »
Hôtes internes découvrables depuis le client connecté	3 / 3 (vm-client, vm-securite, vm-serveur)
Services exposés sur la ressource cible vm-serveur	2 (HTTP/80, SSH/22)

Cloisonnement micro-segmenté	Aucun (réseau plat 192.168.50.0/24)
-------------------------------------	--

Ces résultats confirment expérimentalement les hypothèses H1 et H2 du chapitre 4. Ils démontrent concrètement le risque structurel du modèle périmétrique : la compromission d'un seul jeu d'identifiants VPN ouvre la voie à une exploration libre de l'ensemble du réseau interne, et à des tentatives de mouvement latéral vers des cibles plus sensibles. C'est précisément cette propriété que les solutions ZTNA modernes prétendent éliminer — propriété que la phase 2 de notre étude testera de manière comparative.

6.3 Synthèse comparative des résultats VPN

Pour conclure cette analyse de phase 1, nous présentons le tableau de synthèse rassemblant l'ensemble des indicateurs mesurés. La colonne « ZTNA Pomerium » sera complétée lors de la phase 2.

Tableau 9 — Synthèse comparative complète des résultats VPN

Indicateur	Baseline (sans VPN)	OpenVPN
Latence moyenne (ms)	1,53	3,55
Débit TCP (Mbits/s)	805	8,81
Gigue UDP (ms)	0,77	5,11
Perte UDP @ 100 Mb (%)	0	92
Temps HTTP moyen (ms)	7,4	11,1
Ports exposés	—	2 (1194/UDP, 22/TCP)
Déplacement latéral	—	Possible

6.4 Discussion et confrontation aux hypothèses

Les résultats collectés permettent une première confrontation à nos hypothèses, dans la limite de ce qu'autorise la phase 1 du projet (les conclusions définitives nécessitent les données ZTNA de la phase 2).

Hypothèse H1 (réduction de la surface d'attaque). L'architecture VPN expose effectivement une surface d'attaque mesurable : 2 ports/services publics identifiables, dont 1

service VPN clairement signé. Cette mesure constitue la référence à comparer avec le déploiement ZTNA, où l'hypothèse postule une surface nulle (« network goes dark »).

Hypothèse H2 (blocage du déplacement latéral). L'architecture VPN permet effectivement le déplacement latéral, ce que nous avons démontré expérimentalement : un client connecté au VPN peut découvrir l'intégralité des hôtes du réseau interne et identifier leurs services exposés. Cette mesure est conforme à l'analyse théorique du chapitre 2 et constitue la limite structurelle majeure du modèle périmétrique.

Hypothèse H3 (coût en performance). L'architecture VPN impose un coût substantiel en performance dans notre environnement : $\times 2,3$ sur la latence, $\div 91$ sur le débit TCP, $\times 6,6$ sur la gigue UDP, 92 % de perte sous charge UDP. Ces résultats sont à interpréter en tenant compte des spécificités de notre déploiement (virtualisation sans accélération matérielle), mais ils illustrent fidèlement la nature de la dégradation introduite par le tunnel chiffré.

L'analyse comparative finale, intégrant les résultats du déploiement ZTNA, permettra de tirer des conclusions définitives sur la pertinence du modèle Zero Trust comme alternative au VPN classique. Ces conclusions feront l'objet de la section finale du chapitre 6 et de la conclusion générale du rapport.

Conclusion générale

Le présent rapport a présenté une étude scientifique de la transition entre deux paradigmes d'accès distant en entreprise : le VPN classique, héritier du modèle périmétrique, et le Zero Trust Network Access, qui incarne une rupture architecturale conceptuelle. Cette étude, menée dans le cadre de l'Application de la Démarche Scientifique au CESI École d'Ingénieurs, a respecté les cinq étapes méthodologiques attendues : cadrage du sujet, analyse de l'existant, état de l'art, proposition expérimentale, validation par mesure.

Bilan du travail accompli

Au plan théorique, nous avons explicité les fondements du modèle périmétrique et identifié ses cinq limites structurelles (confiance implicite, absence de micro-segmentation, surface d'attaque exposée, absence de vérification du poste client, dégradation des performances). Nous avons ensuite présenté le modèle Zero Trust à travers ses trois principes fondamentaux (vérification explicite, accès au moindre privilège, présumer la brèche) et ses cinq piliers techniques (identité, appareils, réseau, applications, données), en nous appuyant sur les références normatives du domaine (NIST SP 800-207, CISA Zero Trust Maturity Model).

Au plan expérimental, nous avons conçu, déployé et instrumenté un banc d'essai à trois machines virtuelles permettant la mesure rigoureuse des performances et de la posture sécuritaire d'une architecture d'accès distant. La phase 1 du projet — déploiement d'OpenVPN — a été menée à son terme : la PKI a été générée via Easy-RSA, le serveur configuré avec AES-256-GCM sur UDP/1194, le forwarding IP et le NAT MASQUERADE mis en place, le client connecté avec succès, et un ensemble complet de mesures collectées selon un protocole reproductible.

Réponse partielle à la problématique

Notre problématique interrogeait la possibilité de garantir un accès distant sécurisé sans dégrader les performances. Les mesures effectuées sur l'architecture VPN établissent un constat clair : le modèle périmétrique impose un compromis sécurité-performance défavorable. Côté sécurité, la surface d'attaque est mesurable (deux ports exposés, dont un service VPN nativement identifiable par scan) et le déplacement latéral est démontré expérimentalement. Côté performance, le tunnel chiffré multiplie la latence par 2,3, divise le débit TCP par 91 dans nos conditions de test, et fait perdre 92 % des paquets sous charge UDP.

La réponse définitive à la problématique nécessite la comparaison avec le modèle ZTNA, qui constitue la phase 2 du projet. Le travail préparatoire de cette phase a été réalisé (choix de Pomerium argumenté, architecture définie, plan de déploiement détaillé, métriques de comparaison identiques retenues), mais le déploiement effectif et les mesures correspondantes n'ont pu être conduits dans le calendrier disponible. Ils constituent la perspective immédiate du projet et seront menés à brève échéance.

Apports personnels et compétences développées

Ce projet ADS m'a permis de développer un ensemble de compétences techniques et méthodologiques précieuses pour la suite de mon parcours d'ingénieur. Sur le plan technique, j'ai consolidé ma maîtrise de l'administration système Linux (Debian 13), de la virtualisation (VirtualBox), des principes de la cryptographie appliquée (PKI X.509, TLS, AES-256-GCM), du routage IP avancé (NAT MASQUERADE, conflits de routes, persistance des configurations système), et des outils de mesure réseau (ping, iperf3, nmap, curl, tcpdump).

Sur le plan méthodologique, j'ai mis en pratique la rigueur de la démarche scientifique : formulation explicite d'hypothèses avant l'expérimentation, conception d'un protocole de mesure reproductible, collecte de données suffisamment volumineuses pour permettre une analyse statistique, interprétation honnête des résultats incluant leurs limites. La rédaction du présent rapport et la préparation du poster de soutenance ont également renforcé ma capacité à communiquer un travail technique à différents publics.

Au-delà des compétences, ce projet a renforcé une posture intellectuelle : aborder un sujet technique non pas par des affirmations de catalogue, mais par une démarche de vérification et de mesure. C'est cette posture, autant que les compétences techniques, qui constituera ma véritable plus-value en tant qu'ingénieur.

Perspectives

Plusieurs perspectives s'ouvrent à l'issue de ce travail. La première et la plus directe est la finalisation de la phase 2 (déploiement Pomerium et mesures comparatives), qui permettra de répondre complètement à la problématique. Au-delà, plusieurs pistes d'approfondissement méritent d'être mentionnées : l'intégration d'un fournisseur d'identité d'entreprise (Keycloak auto-hébergé, ou Azure AD en environnement Microsoft) pour évaluer la maturité du modèle d'identité ; l'ajout d'une dimension Device Trust avec posture check avancée (vérification de la conformité du poste client) ; la conduite de tests de montée en charge avec utilisateurs simultanés pour évaluer le comportement des deux architectures en condition opérationnelle ; et enfin la comparaison de Pomerium avec d'autres solutions ZTNA (commerciales comme Cloudflare Access ou Zscaler Private Access, ou open source comme Teleport ou OpenZiti).

Ce projet ADS aura donc rempli son ambition première : celle de transformer un sujet d'actualité de la cybersécurité en démarche scientifique structurée, ouvrant sur des perspectives concrètes d'investigation ultérieure.

Bibliographie

Normes et publications de référence

- [1] ROSE, S. et al. (2020). *Zero Trust Architecture*. NIST Special Publication 800-207. National Institute of Standards and Technology. Disponible en ligne sur : <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>
- [2] CISA — Cybersecurity and Infrastructure Security Agency (2023). *Zero Trust Maturity Model, Version 2.0*. Disponible en ligne sur : <https://www.cisa.gov/zero-trust-maturity-model>
- [3] KINDERVAG, J. (2010). *No More Chewy Centers: Introducing the Zero Trust Model of Information Security*. Forrester Research.
- [4] ANSSI — Agence Nationale de la Sécurité des Systèmes d'Information. *Recommandations relatives au télétravail et à l'accès distant*. Disponible sur : <https://www.ssi.gouv.fr>

Documentation technique

- [5] OPENVPN INC. *OpenVPN 2.6 — Reference Manual*. Disponible sur : <https://openvpn.net/community-resources/reference-manual-for-openvpn-2-6/>
- [6] POMERIUM INC. *Pomerium — Open Source Zero Trust Access*. Documentation officielle disponible sur : <https://www.pomerium.com/docs/>
- [7] DEBIAN PROJECT (2025). *Debian 13 (Trixie) — Release Notes*. Disponible sur : <https://www.debian.org/releases/trixie/>

Rapports et études du marché

- [8] GARTNER (2023). *Market Guide for Zero Trust Network Access*.
- [9] VERIZON (annuel). *Data Breach Investigations Report (DBIR)*. Disponible sur : <https://www.verizon.com/business/resources/reports/dbir/>
- [10] FORRESTER RESEARCH. *The Forrester Wave : Zero Trust Network Access Solutions*.

Ressources complémentaires

- [11] MICROSOFT (2024). *Zero Trust Architecture — Microsoft Learn*. Disponible sur : <https://learn.microsoft.com/en-us/security/zero-trust/>
- [12] GOOGLE (2014). *BeyondCorp — A New Approach to Enterprise Security*. Publication Google Research.